



14a-intro-to-security

Güvenlik Nedir ve Neye Göre Tanımlanır?

Bir sistemin, uygulamanın veya protokolün güvenliği, her zaman iki şeye bağlı olarak değerlendirilir:

1. **İstenen özellikler kümesi** (gizlilik, bütünlük, erişilebilirlik gibi)
2. **Saldırganın yetenekleri** (örneğin, bir saldırgan bilgisayarı CD ile yeniden başlatabiliyorsa, Linux/Windows dosya izinleri işe yaramaz)

Bu, güvenliğin mutlak olmadığını, bir bağlamı olduğunu gösterir.

CIA Üçlüsü

Güvenliğin üç temel bileşeni vardır. Bunların İngilizce baş harfleri **CIA**'dır (Confidentiality, Integrity, Availability).

1. Gizlilik (Confidentiality)

- **Ne demek?** Bilginin veya kaynakların yetkisiz kişilerce görülmesini engellemek.
- **Örnek:** Üniversitede bazı odalara girememek, öğrenci bilgi sisteminde başka öğrencilerin notlarını görememek.
- **Nasıl sağlanır?** Erişim kontrol mekanizmaları, şifreleme (kriptografik anahtar).

2. Bütünlük (Integrity)

- **Ne demek?** Bilginin güvenilir olması, yetkisiz değişikliklere uğramamış olması.
- **İki türü vardır:**
 - **Veri bütünlüğü:** Verinin kendisi değiştirilmemiş.
 - **Kaynak bütünlüğü (origin integrity):** Verinin gerçekten söylendiği kaynaktan geldiğinin doğrulanması (kimlik doğrulama ile).

- **Mekanizmalar:**

- **Önleme (prevention):** Yetkisiz değişiklikleri engelleme.
- **Tespit (detection):** Değişiklik olduysa bunu raporlama (örneğin checksum).

3. Erişilebilirlik (Availability)

- **Ne demek?** Yetkili kullanıcıların bilgiye veya kaynağa zamanında ve kesintisiz erişebilmesi.
- **Tehdit:** Erişilebilirliği engelleme girişimlerine **Denial of Service (DoS)** saldırısı denir.

Gizlilik Sağlama Araçları

Şifreleme (Encryption)

- Bilgiyi, gizli bir anahtar kullanarak okunamaz hale getirme. Sadece doğru çözme anahtarı (decryption key) ile orijinal hale döndürülür.

Erişim Kontrolü (Access Control)

- Hangi kullanıcı veya sürecin hangi dosyaya ne tür erişim (okuma, yazma, çalıştırma, sahiplik) hakkı olduğunu belirten kurallar ve politikalar.

Kimlik Doğrulama (Authentication)

- Bir kişinin veya sistemin kimliğini veya rolünü belirleme. Üç temel yöntem:
 - **Sahip olduğu bir şey** (akıllı kart, anahtarlık)
 - **Bildiği bir şey** (şifre)
 - **Kendisi olduğu bir şey** (parmak izi, biyometri)

Yetkilendirme (Authorization)

- Erişim kontrol politikasına dayanarak, bir kişi veya sistemin kaynağa erişip erişemeyeceğine karar verme. Yetkilendirme, kimlik doğrulamadan sonra gelir.

Fiziksel Güvenlik (Physical Security)

- Fiziksel bariyerler (kilitli dolaplar, kapılar, penceresiz odalar, Faraday kafesi gibi) ile koruma. Faraday kafesi, elektromanyetik sinyallerin içeri/dışarı girmesini engelleyen bakır ağılı duvarlardır.

Bütünlüğü Sağlama Araçları

Yedekleme (Backups)

- Verinin periyodik olarak arşivlenmesi.

Checksum (Sağlama Toplamı)

- Dosyanın tüm içeriğinden hesaplanan sayısal bir değer. Dosyada tek bir bit bile değişse, checksum büyük olasılıkla değişir. Böylece bozulma tespit edilebilir.

Veri Düzeltken Kodlar (Data Correcting Codes)

- Veriyi öyle bir şekilde saklar ki küçük değişiklikler otomatik olarak algılanıp düzeltilebilir.

Erişilebilirliği Sağlama Araçları

Fiziksel Korumalar

- Yangın, sel, elektrik kesintisi gibi fiziksel olaylara karşı altyapı (jeneratör, yangın söndürme sistemi).

Hesaplamalı Yedeklilik (Computational Redundancies)

- Yedek bilgisayarlar ve depolama aygıtları. Birisi çökerse diğeri devreye girer.

Tehditler ve Saldırı Türleri

Dört Ana Tehdit Sınıfı

- Açığa Çıkarma: Bilgiye yetkisiz erişim sağlamak.
- Aldatma: Yanlış veriyi kabul ettirmek.
- Kesinti: Çalışmayı engellemek veya kesintiye uğratmak.

- Ele Geçirmek: Sistemin bir kısmının yetkisiz kontrolünü ele geçirmek.

Erişim Kontrolü

Erişim Kontrolü Matrisi

Bir erişim kontrol matrisi, satırları **özneler (subjects)** (genellikle kullanıcılar veya süreçler), sütunları **nesnelere (objects)** (dosyalar, yazıcılar, dizinler vb.) ayıran bir tablodur. Her hücrede, ilgili öznenin o nesne üzerindeki **erişim hakları** (okuma, yazma, çalıştırma, sahiplik vb.) yazılır.

Özne \ Nesne	dosya1.txt	dosya2.txt	yazıcı
ali	okuma, yazma	okuma	yazma
ayşe	okuma	okuma, yazma	-
root	tüm haklar	tüm haklar	tüm haklar

Bu matris teorik olarak güçlüdür, ancak pratikte çok büyük olur (binlerce kullanıcı ve milyonlarca dosya için devasa bir tablo gerekir). Bu yüzden gerçek sistemler bu matrisi iki farklı şekilde uygular:

1. **Erişim kontrol listeleri (ACL)** – Nesne merkezli.
2. **Yetkiler (Capabilities)** – Özne merkezli.

Erişim Kontrolü Listeleri

Bir erişim kontrol listesi, her **nesne** için, o nesneye erişmek isteyen **tüm özneleri** ve onların haklarını listeleyen bir yapıdır.

Yani dosya1.txt için bir ACL şöyle olabilir:

- ali: okuma, yazma
- ayşe: okuma

- root: tüm haklar

Yetkiler

Yetkiler, erişim kontrol matrisinin **özne merkezli** temsilidir. Her **özne** için, o öznenin erişebildiği **tüm nesneleri** ve bu nesneler üzerindeki haklarını listeleyen bir yapıdır.

Yani ali için bir yetki listesi şöyle olabilir:

- dosya1.txt: okuma, yazma
- dosya2.txt: okuma
- yazıcı: yazma

Rol Tabanlı Erişim Kontrolü (Role-Based Access Control – RBAC)

RBAC, doğrudan kullanıcılara hak vermek yerine, **roller** tanımlar ve hakları rollere atar. Kullanıcılar da bu rollere atanır.

Örnek: Bir hastane sisteminde şu roller olabilir:

- Doktor: hastaların tıbbi kayıtlarını okuyabilir ve yazabilir.
- Hemşire: sadece okuyabilir, yazamaz.
- Hasta: sadece kendi kayıtlarını okuyabilir.

Kriptografi

Temel Kavramlar

- **Düz metin (Plaintext, M):** Şifrelenmemiş, okunabilir orijinal mesaj.
- **Şifreleme algoritması (Encryption algorithm, E):** Düz metni şifreli metne dönüştüren matematiksel işlem.
- **Şifreli metin (Ciphertext, C):** Şifrelenmiş, okunamaz haldeki mesaj.
- **Şifre çözme algoritması (Decryption algorithm, D):** Şifreli metni tekrar düz metne dönüştüren işlem.

Simetrik (Tek Anahtarlı) Kriptosistemler

Alice ve Bob aynı gizli anahtarı paylaşırlar. Bu anahtar hem şifreleme hem de şifre çözme için kullanılır.

Tarihsel Örnekler

- **Yerine koyma şifresi (Substitution cipher):** Harfleri başka harflerle değiştirme (Sezar şifresi gibi).
- **Yer değiştirme şifresi (Transposition cipher):** Harflerin sırasını değiştirme.
- **Vigenère şifresi:** Bir anahtar kelime kullanarak harfleri kaydırma.
- **Tek kullanımlık şifre (One-time pad):** Anahtar, mesajla aynı uzunluktadır ve yalnızca bir kez kullanılır. Teorik olarak kırılmaz, ama anahtar dağıtımı pratikte zordur.

Simetrik Şifrelemenin Özellikleri

- **Hızlıdır:** Büyük verileri şifrelemek için idealdir.
- **Anahtar dağıtım sorunu vardır:** Alice ve Bob'un aynı anahtarı güvenli bir şekilde paylaşması gerekir. Bu anahtarı nasıl iletecekler? (Sayfa 33'te bu soru vurgulanır.)

Asimetrik (Açık Anahtarlı) Kriptografi

İki farklı anahtar kullanılır:

- **Açık anahtar (Public key):** Herkese açıktır. Şifreleme için kullanılır.
- **Özel anahtar (Private key):** Sadece sahibi bilir. Şifre çözme için kullanılır.

Önemli: Açık anahtarla şifrelenen bir mesajı, sadece ilgili özel anahtar çözebilir. Özel anahtarla şifrelenen bir mesajı ise herkes açık anahtarla çözebilir (bu, dijital imza için kullanılır).

RSA Algoritması

RSA, en bilinen asimetrik şifreleme algoritmasıdır.

Matematiksel mantığı şöyledir:

1. İki büyük asal sayı seçilir: p ve q .
2. $n = p * q$ hesaplanır.
3. $\phi(n) = (p-1)*(q-1)$ hesaplanır (Euler'in totient fonksiyonu).
4. e sayısı seçilir. e , $\phi(n)$ ile aralarında asal (ortak böleni 1) olmalı ve $1 < e < \phi(n)$ koşulunu sağlamalıdır.
5. d sayısı hesaplanır: $(e * d) \bmod \phi(n) = 1$ olacak şekilde bir d bulunur.
 - **Açık anahtar:** (e, n) çiftidir.
 - **Özel anahtar:** d sayısıdır (ve n bilinir).

Şifreleme: $c = m^e \bmod n$ (m düz metin, c şifreli metin)

Şifre çözme: $m = c^d \bmod n$

Kriptografik Özet Fonksiyonları

Bir mesajdan sabit uzunlukta bir "parmak izi" çıkaran fonksiyondur. (Örneğin SHA-256, 256 bitlik bir çıktı verir.)

İki temel özelliği vardır:

1. **Tek yönlülük (One-way):** Bir mesajın özetini hesaplamak kolaydır, ancak bir özet değerinden orijinal mesajı bulmak çok zordur.
2. **Çarpışmaya dirençli (Collision-resistant):** Aynı özet değerini verecek iki farklı mesaj bulmak çok zordur. (Yani $H(M) = H(N)$ olacak şekilde $M \neq N$ bulmak pratik olarak imkansızdır.)

Mesaj Doğrulama Kodları (Message Authentication Codes – MAC)

Alice ve Bob'un paylaştığı gizli bir anahtar (K) kullanarak, bir mesajın hem bütünlüğünü hem de kaynağının doğruluğunu sağlayan yapıdır.

Nasıl çalışır?

- Alice, mesajı (M) ve gizli anahtarı (K) alır, $H(K || M)$ hesaplar (burada $||$ birleştirme anlamında, pratikte daha karmaşık yapıdır).
- Alice, hem M 'yi hem de bu MAC değerini Bob'a gönderir.

- Bob, aynı **K** ile aynı hesabı yapar. Kendi hesapladığı değer, gelen MAC ile eşleşiyorsa, mesaj değişmemiş ve Alice'ten geldiği doğrulanmış olur.

MAC ile dijital imza arasındaki fark:

- MAC: simetrik anahtar kullanılır, yadsımama (non-repudiation) sağlamaz çünkü Bob da aynı anahtarla MAC üretebilir.
- Dijital imza: asimetrik anahtar kullanılır, yadsımama sağlar.

Dijital Sertifikalar

Bir sertifika otoritesi (Certificate Authority – CA), bir kimlik ile o kimliğe ait açık anahtar arasındaki bağlantıyı **dijital olarak imzalar**.

Asimetrik şifrelemede, Alice Bob'un açık anahtarını nasıl doğrulayabilir? Ya bir saldırgan kendi açık anahtarını "Bob'un açık anahtarı" diye yayınlarsa? Sertifikalar, bu sorunu çözer.

Nasıl çalışır?

- Bob, kimlik belgeleriyle bir CA'ya gider.
- CA, Bob'un kimliğini doğrular ve "Bob'un açık anahtarı budur" diyen bir belgeyi kendi özel anahtarıyla imzalar. Bu belgeye **dijital sertifika** denir.
- Alice, Bob'un sertifikasını alır, CA'nın açık anahtarını kullanarak imzayı doğrular. Doğrulama başarılıysa, sertifikadaki açık anahtarın gerçekten Bob'a ait olduğunu anlar.